FSCT 8561 — Lab 3 Rubric

Instructor: Maryam R.Aliabadi

Total points: 100

Component	Full Credit	Partial Credit	Minimal / No Credit	Points
Password Hashing & Verification	Correctly hashes passwords; stores only password hashes; correctly verifies submitted passwords; plaintext passwords are not stored in the user database	Hashing works but has minor implementation or verification issues	Passwords stored in plaintext, hashing missing, or verification substantially incorrect	**15**
TOTP Secret Generation & Account Setup	Generates a valid Base32 secret, correctly associates it with the user account, and consistently uses the same secret for authentication	Secret generated but account association or reuse has minor issues	Secret missing, regenerated incorrectly during authentication, or TOTP unusable	**10**
TOTP Generation & Verification	Correctly generates/verifies TOTP; accepts valid OTP and rejects invalid/expired OTP with appropriate responses	OTP verification generally works but has inconsistent handling or minor errors	OTP verification missing/incorrect or invalid OTP grants access	**15**
Authentication Protocol & State Management	Correctly implements AUTH → password verification → OTP_REQUIRED → OTP verification → ACCESS_GRANTED; prevents OTP from bypassing password stage	Authentication flow works but has minor state/protocol problems	Authentication stages can be bypassed or workflow is substantially incorrect	**15**
Client–Server Implementation	auth_server.py and auth_client.py communicate correctly; client collects username/password/OTP appropriately; uses getpass(); responses are clear; sockets close cleanly	Core client-server interaction works but has minor input, communication, or cleanup issues	Client/server substantially incomplete or unable to complete authentication	**15**
Robustness & Security Testing	Correctly handles invalid username, incorrect password, invalid/expired OTP, OTP before password, malformed messages, and other required tests without crashing	Most required cases handled, with some missing or inconsistent behavior	Limited error handling or server crashes on common invalid inputs	**10**

Component	Full Credit	Partial Credit	Minimal / No Credit	Points
Failed-Login Protection	Correctly tracks failed authentication attempts, enforces the required maximum-attempt policy, prevents further authentication as specified, and handles the counter/state correctly	Counter or restriction generally works but has minor logic/state issues	Failed-attempt protection missing or can be easily bypassed due to implementation errors	**10**
Security Reflection & Analysis	Reflection answers demonstrate clear understanding; 300–400 word analysis explicitly discusses the implementation, password hashing, TOTP, replay/credential risks, raw TCP limitations, TOTP-secret compromise, repeated attempts, and realistic improvements	Generally correct but lacks depth, misses some required issues, or is weakly connected to the implementation	Missing, generic, substantially inaccurate, or does not analyze the implemented system	**10**